

Phishing Awareness Training

A Guide to Identifying, Neutralizing, and Reporting Social Engineering Threats

EXECUTIVE DIRECTIVE & OBJECTIVES

Phishing remains the single most common primary attack vector utilized by threat actors to infiltrate enterprise networks. This document establishes standard operational awareness protocols for identifying suspicious communications, understanding psychological manipulation techniques, and responding effectively to potential security incidents.

Key Objectives:

- Understand the modern threat landscape and social engineering tactics.
- Recognize psychological triggers designed to bypass critical evaluation.
- Detect behavioral, domain, and technical red flags across digital communications.
- Execute standard 3-step incident response and reporting protocols.
- Safely inspect embedded links and attachments prior to interaction.

TRAINING LEVEL	ESTIMATED TIME	TARGET AUDIENCE
Mandatory Core	15 - 20 Minutes	All Staff & Personnel

1. Introduction: The Threat Landscape & Human Factors

Modern cybersecurity perimeter defenses—such as next-generation firewalls, automated endpoint detection and response (EDR), and sophisticated spam filtering—have made direct technical breaches increasingly difficult for cybercriminals. Consequently, attackers have shifted their focus toward exploiting the weakest link in any organizational defense: **human psychology**.

Phishing is defined as a fraudulent attempt to obtain sensitive information or access by disguising as a trustworthy entity in an electronic communication. Over **90% of all successful corporate data breaches originate through a single phishing email**. A single set of compromised credentials can grant adversaries lateral movement access across internal corporate networks, leading to ransomware deployment, intellectual property theft, or direct financial loss.

Primary Categories of Phishing Attacks

Phishing has evolved beyond generic spam messages. Threat actors utilize specialized formats to target specific business workflows:

Vector Type	Description & Attack Methodology
Spear Phishing	Highly customized attacks targeting specific individuals or teams using open-source intelligence (OSINT) gathered from social media and corporate websites.
Whaling (CEO Fraud)	Targeted attacks impersonating high-level executives to deceive employees into approving unauthorized wire transfers or releasing confidential records.
Smishing & Vishing	Phishing conducted via SMS text messages (Smishing) or voice calls (Vishing), often claiming urgent bank fraud or MFA verification requests.
Clone Phishing	Intercepting or copying a legitimate, previously delivered email containing an attachment or link, and resending a modified version with malicious payloads.

2. Anatomy of a Phishing Attack: Psychological Triggers

Social engineering relies entirely on emotional manipulation rather than software vulnerability exploitation. Threat actors design messages that deliberately trigger cognitive biases to bypass an employee's natural skepticism:

Trigger	Attacker Strategy	Behavioral Impact
Urgency	Imposes artificial deadlines (e.g., <i>'Account terminates in 1 hour'</i>).	Forces fast execution; prevents independent consultation.
Fear	Threatens severe consequences (e.g., legal action, job termination).	Induces panic, causing targets to follow instructions blindly.
Authority	Impersonates corporate leaders, legal authorities, or IT directors.	Leverages workplace deference to command compliance.
Greed / Curiosity	Offers fake bonuses, confidential salary lists, or gift cards.	Encourages targets to click impulsively without verification.

3. Technical & Behavioral Red Flags

Before opening attachments, clicking links, or replying to unsolicited messages, perform a comprehensive inspection of all incoming communications using the following checklist:

Category	Inspection Methodology & Anomaly Details	Risk Level
Sender Address & Typosquatting	Examine the full email header and domain suffix. Watch for look-alike domains that replace letters with similar characters (e.g., <i>john.smith@microsoft.com</i> or <i>paypa1.com</i>).	CRITICAL
Embedded Links & Mismatches	Hover your cursor over links (without clicking) to preview the true destination URL. Verify that the domain matches the official corporate domain exactly.	CRITICAL
Generic Salutations	Messages using vague greetings such as 'Dear Customer' or 'Valued Employee' indicate mass automated spam distributions rather than legitimate targeted correspondence.	MEDIUM
High-Risk Attachments	Be extremely cautious of unexpected files, double file extensions (e.g., <i>Document.pdf.exe</i>), compressed archives (.zip, .rar), or macro-enabled Office files (.docm, .xlsm).	CRITICAL
Out-of-Band Payment Requests	Unsolicited emails demanding wire transfers, changes to vendor banking details, or gift card purchases are nearly always fraudulent.	CRITICAL
Inconsistent Tone / Grammar	Uncharacteristic language, poor spelling, or awkward syntax from known contacts often indicates account compromise.	MEDIUM

SAFELY INSPECTING EMBEDDED LINKS

1. **Never click a link directly** in an unverified or suspicious email message.
2. **Hover over the hyperlink text** using your mouse cursor to reveal the actual destination web address.
3. Look closely at the primary domain (the segment directly before .com or .org). For example, *security.company.com* is a legitimate subdomain of *company.com*, whereas *company.com.attacker-site.com* actually belongs to *attacker-site.com*.
4. If in doubt, navigate to the official website manually via your standard browser bookmarks rather than relying on email hyperlinks.

4. Real-World Threat Scenarios & Analysis

Examine these realistic threat scenarios based on actual cyber incident investigations to understand how attacks unfold in everyday business operations:

Case Study 1: Executive Impersonation (CEO Fraud / Business Email Compromise)

Scenario: An executive assistant receives an urgent email appearing to come from the CEO, who is currently attending an international conference. The message states that a confidential acquisition is underway and demands an immediate \$45,000 wire transfer to an escrow account.

Red Flags Identified: High-urgency demand, request to bypass standard finance approval workflows, external reply-to address mismatch upon detailed inspection.

Correct Operational Action: Never execute financial transfers based solely on email instructions. Always conduct out-of-band verification via phone or direct verbal confirmation using known internal contact numbers.

Case Study 2: IT Helpdesk Multi-Factor Authentication (MFA) Fatigue

Scenario: An employee receives an email claiming their Microsoft 365 password expires in 15 minutes. Clicking the link leads to a convincing fake login page. After entering credentials, the employee receives repeated MFA push notifications on their phone.

Red Flags Identified: Strict artificial time limit, non-standard domain URL hosting the login form, unsolicited MFA prompt storming.

Correct Operational Action: IT personnel will never demand immediate password resets via direct email links. Access internal administration portals via official corporate bookmarks and deny all unexpected MFA prompts.

Case Study 3: Fraudulent Vendor Account Update

Scenario: An accounts payable specialist receives an email from a long-term vendor attaching an invoice and notifying that their receiving bank routing details have changed due to an annual financial audit.

Red Flags Identified: Unannounced banking detail changes, subtle domain typo in sender address (e.g., *@sup-plier.com* instead of *@supplier.com*).

Correct Operational Action: Hold payment processing immediately. Independently contact the vendor's finance department using the phone number listed on previously verified contracts.

5. What to Do If You Spot a Phish: Response Protocol

If you suspect an email is malicious, adhere strictly to the standardized 3-step incident response protocol below to ensure organizational safety:

STEP 1	DO NOT ENGAGE	Do not click any embedded links, open attached files, reply to the sender, or forward the message to coworkers.
STEP 2	REPORT IMMEDIATELY	Click the official 'Report Phishing' button in your email client ribbon or forward the email as an attachment to <i>security@company.com</i> .
STEP 3	CONTAIN IMPACT	If you inadvertently entered credentials or downloaded a file, immediately disconnect your ethernet cable/Wi-Fi and call the Security Operations Hotline.

Best Practices & Ongoing Vigilance

Cyber threats continuously evolve, but following standard operational hygiene drastically reduces risk:

CORE REMINDERS FOR DAILY OPERATIONS

- **Verify Out-of-Band:** Always confirm unscheduled financial or credential requests using a trusted secondary contact method.
- **Inspect Domains:** Carefully review sender addresses and URLs for subtle misspellings or abnormal domain extensions.
- **Protect Credentials:** Organizational passwords should never be entered on external third-party sites or forms.
- **Report Promptly:** Reporting suspicious messages helps Security Teams update perimeter filters to protect all employees.